COMPTIA SECURITY+ SY0-701 DOMAIN 4 · SECURITY OPERATIONS (28%)

Security+ 4.3 · Threat Intelligence

Mestre CyberSec · **Lesson 4.3 — Threat Intelligence** (4:46) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Inteligência de ameaça: OSINT (informação ABERTA sobre o atacante); feed de terceiro (CrowdStrike, RecordedFuture); compartilhamento da comunidade (FS-ISAC); dark web (cuido do dado vazado). Resultado: IOCs (IP, hash, domínio).

💡 Key Exam Highlights & Critical Concepts

- OSINT: informação pública que revela o risco ANTES do ataque
- Threat feed + SIEM/EDR = bloqueio e detecção

🎯 Exam Tips & Typical CompTIA Scenarios

- 'publicly available information used for intelligence'=OSINT

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 4.3 — Threat Intelligence)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Open Source Intelligence (OSINT)
Publicly available information collected from open sources (social media, news, websites, public databases) used to identify potential threats and adversary tactics before an attack occurs.

⚠️ ***Exam Trap:*** *If the question says 'publicly available information used for intelligence' → answer is OSINT. The key trigger is the word 'public/open'.*

• Indicators of Compromise (IOC)
Observable artifacts such as IP addresses, file hashes, domains, or URLs that indicate a system has been breached or is under attack.

⚠️ ***Exam Trap:*** *IOCs are the OUTPUT of threat intelligence (IPs, hashes, domains). Do not confuse with IOAs (Indicators of Attack), which are proactive indicators.*

• Threat Feed (Third-Party Intelligence) (N/A)
A continuous stream of threat data provided by commercial vendors (e.g., CrowdStrike, Recorded Future, FireEye) used to enrich SIEM/EDR systems for real-time detection and blocking.

⚠️ ***Exam Trap:*** *Threat feeds integrate with SIEM/EDR for automated blocking. If the question mentions a commercial threat data subscription → threat feed.*

• Information Sharing and Analysis Center (ISAC)
Industry-specific communities (e.g., FS-ISAC for finance, H-ISAC for healthcare) where organizations share threat intelligence, IOCs, and best practices collaboratively.

⚠️ ***Exam Trap:*** *If the question mentions 'community-based threat sharing within an industry sector' → ISAC. Don't confuse with CERT (handles incidents) or ISAO (broader).*

• Dark Web Monitoring (N/A)
Surveillance of hidden networks (Tor, I2P) to detect leaked credentials, stolen data, or planned attacks being sold or discussed by threat actors.

⚠️ ***Exam Trap:*** *When a question mentions monitoring for 'leaked/stolen data' or 'threat actor activity in hidden networks' → Dark Web. Distinct from Deep Web (legitimate but not indexed).*

• **Structured Threat Information eXpression (STIX)**

A standardized language (JSON-based) developed by MITRE/ OASIS used to describe cyber threat intelligence in a structured, machine-readable format.

⚠️ ***Exam Trap:*** *STIX = the FORMAT/LANGUAGE for sharing threat intel. Always paired with TAXII (the transport). Know the pairing: STIX+TAXII.*

• **Trusted Automated eXchange of Intelligence Information (TAXII)**

An application-layer protocol (HTTPS-based) that defines how threat intelligence is exchanged and transported between organizations, typically used to deliver STIX data.

⚠️ ***Exam Trap:*** *TAXII = the TRANSPORT/MECHANISM for threat intel sharing. If asked 'how is threat intel shared/delivered' → TAXII; 'in what format' → STIX.*

• **Automated Indicator Sharing (AIS)**

A DHS/CISA initiative enabling the real-time, machine-to-machine exchange of cyber threat indicators (using STIX/TAXII) between the government and the private sector.

⚠️ ***Exam Trap:*** *AIS = government-driven automated sharing. Mentioned on the exam in the context of real-time, machine-to-machine threat intel distribution.*

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A security analyst at a manufacturing company is asked to collect publicly available information about an attacker group that has been targeting industrial firms. The analyst is told to use only information from search engines, social media, domain registration records, and public forums because the company has no paid intelligence subscriptions. Which intelligence source is the analyst using?

A) Open Source Intelligence (OSINT)

B) Third-party threat feed

C) Dark web monitoring

D) Information Sharing and Analysis Center (ISAC)

QUESTION 2 · EXAM SCENARIO

After containing a malware outbreak, an incident responder extracts a SHA-256 file hash, a malicious IP address, and a command-and-control domain from the affected endpoint and firewall logs. The responder wants to document these artifacts so the SOC can detect the same threat in the future. What is the best term for these artifacts?

A) Tactics, Techniques, and Procedures (TTPs)

B) Indicators of Compromise (IOCs)

C) Common Vulnerabilities and Exposures (CVEs)

D) Structured Threat Information eXpression (STIX) objects

QUESTION 3 · EXAM SCENARIO

A multinational company subscribes to a commercial service that provides curated, contextualized threat intelligence from multiple sources, including malware analysis and actor tracking. The security team wants to reduce the time spent collecting and normalizing raw data from disparate sources. Which type of intelligence source are they using?

A) Open Source Intelligence (OSINT)

B) Third-party threat feed

C) Dark web monitoring service

D) Internal vulnerability scanner

QUESTION 4 · EXAM SCENARIO

A regional bank wants to receive and share threat intelligence specific to the financial services sector with peer institutions and industry partners under a trusted community agreement. Which type of organization is most appropriate for this need?

A) Information Sharing and Analysis Center (ISAC)

B) National Vulnerability Database (NVD)

C) MITRE ATT&CK

D) Open Web Application Security Project (OWASP)

QUESTION 5 · EXAM SCENARIO

A retail company learns that a vendor is monitoring criminal forums, paste sites, and illegal marketplaces for stolen customer records and employee credentials associated with the company's brand. The vendor does not use publicly indexed search engines for this service. Which threat intelligence activity is the vendor performing?

A) Open Source Intelligence (OSINT) collection

B) Dark web monitoring

C) Attack surface scanning

D) Vulnerability management

QUESTION 6 · EXAM SCENARIO

A SOC wants to automate the exchange of threat intelligence with a partner organization. The team needs a standard language to represent indicators and adversary information, and a standard protocol to transport that intelligence between systems. Which pair of standards should the team implement?

A) STIX and TAXII

B) AIS and OSINT

C) IOC and ISAC

D) CVSS and CPE

QUESTION 7 · EXAM SCENARIO

A company wants to automatically share cyber threat indicators with the U.S. government and other participating organizations in near real time. The security architect is looking for a CISA program that supports automated indicator exchange using standards such as STIX and TAXII. Which program should the architect select?

A) Automated Indicator Sharing (AIS)

B) Open Source Intelligence (OSINT)

C) Information Sharing and Analysis Center (ISAC)

D) MITRE ATT&CK Evaluations

QUESTION 8 · EXAM SCENARIO

A malware analyst wants to create a detection rule that identifies a specific malicious executable regardless of the IP address or domain the malware later contacts. Which indicator of compromise is most appropriate for this requirement?

A) SHA-256 file hash

B) Command-and-control IP address

C) Malicious domain name

D) URL used for payload delivery

QUESTION 9 · EXAM SCENARIO

A security team receives a daily threat feed containing thousands of IP addresses, domains, and file hashes. Analysts are overwhelmed because most indicators are unrelated to the company's industry and technology stack. Which action best improves the operational value of the feed?

A) Filter, enrich, and prioritize indicators based on the organization's assets and threat profile

B) Block every indicator from the feed at the perimeter firewall

C) Disable the feed and rely only on antivirus signatures

D) Store all indicators in a database without creating detections

QUESTION 10 · EXAM SCENARIO

A CISO asks why the company cannot rely only on blocking the IP addresses and file hashes received from a threat feed to stop a sophisticated adversary. Which limitation of atomic indicators should the analyst explain?

A) Indicators are often short-lived and can be changed easily by the adversary

B) Indicators cannot be automated in security tools

C) Indicators always reveal the adversary's true identity

D) Indicators require dark web access to be useful

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option A — Open Source Intelligence (OSINT)

OSINT is intelligence collected from publicly available sources such as search engines, social media, domain registration records, public forums, and government records. Paid feeds, dark web monitoring, and ISACs rely on closed, commercial, or community-private sources, so they do not fit the restriction.

Question 2: Option B — Indicators of Compromise (IOCs)

IOCs are observable artifacts such as file hashes, IP addresses, domains, and URLs that indicate a potential compromise. TTPs describe adversary behavior, CVEs identify vulnerabilities, and STIX is a language/schema for sharing threat intelligence, not the artifacts themselves.

Question 3: Option B — Third-party threat feed

A third-party threat feed provides commercial or vendor-curated intelligence, often with context, scoring, and normalized data from multiple sources. OSINT is publicly available data collected directly, dark web monitoring focuses on criminal forums and marketplaces, and a vulnerability scanner assesses internal systems.

Question 4: Option A — Information Sharing and Analysis Center (ISAC)

An ISAC is a sector-specific community for trusted sharing of threat intelligence. FS-ISAC serves financial services. NVD is a vulnerability database, MITRE ATT&CK is a knowledge base of adversary tactics and techniques, and OWASP focuses on application security guidance.

Question 5: Option B — Dark web monitoring

Dark web monitoring focuses on hidden or criminal sources such as forums, marketplaces, and paste sites that are not indexed by standard search engines. OSINT uses publicly available sources, attack surface scanning identifies exposed assets, and vulnerability management tracks and remediates vulnerabilities.

Question 6: Option A — STIX and TAXII

STIX is a standardized language for representing cyber threat information, and TAXII is an application-layer protocol for exchanging that information. AIS is a U.S. DHS/CISA initiative that can use STIX/TAXII, OSINT is a source type, IOC is an indicator type, ISAC is a sharing community, and CVSS/CPE are vulnerability scoring and naming standards.

Question 7: Option A — Automated Indicator Sharing (AIS)

Automated Indicator Sharing (AIS) is a CISA program that enables near real-time exchange of cyber threat indicators between participants, often using STIX and TAXII. OSINT is a source type, ISACs are sector-sharing communities, and MITRE ATT&CK Evaluations assess products against adversary behavior.

Question 8: Option A — SHA-256 file hash

A cryptographic file hash such as SHA-256 uniquely identifies a specific file sample and remains useful even if the malware changes network infrastructure. IP addresses, domains, and URLs are network-based indicators that may change between campaigns or be shared by benign services.

Question 9: Option A — Filter, enrich, and prioritize indicators based on the organization's assets and threat profile

Threat intelligence must be relevant to the organization's assets, vulnerabilities, and threat model. Filtering, enriching, and prioritizing indicators reduces noise and focuses response. Blocking everything can cause outages, disabling the feed removes useful data, and storing without action provides no detection value.

Question 10: Option A — Indicators are often short-lived and can be changed easily by the adversary

Atomic indicators such as IP addresses and file hashes are valuable but often short-lived because attackers can rotate infrastructure, recompile malware, or use legitimate services. TTP-based intelligence is more durable. Indicators can be automated, do not necessarily reveal identity, and do not require dark web access.